Campo	¿Identifica directamente?	¿Puede contribuir a identificar?	¿Requiere protección?	Justificación
`id`	No	Si	Si	Identificador único del sistema que, al cruzarse con la base de datos, revela la identidad real.
`nombre`	SI	No	Si	Es el identificador directo más básico y evidente de una persona física.
`correo`	Si	No	SI	Medio de contacto único y personal que con frecuencia incluye nombre o seudónimos del titular.
`telefono`	SI	No	Si	Es único, de uso personal directo y permite ubicar o contactar a la persona inmediatamente.
`rfc`	Si	No	Si	Clave gubernamental única que identifica inequívocamente

				a un ciudadano o entidad fiscal.
`edad`	No	Si	Si	Reduce el grupo poblacional y, combinada con otros datos, permite triangular una identidad.
`ciudad`	No	Si	Si	Dato de ubicación general que sirve para acotar la búsqueda o perfilar a un individuo en conjunto con otras variables.
`codigo_postal`	No	Si	Si	Delimita geográficamente a la persona a un nivel barrial o zonal, elevando el riesgo de reidentificación.
`fecha_alta`	NO	NO	NO	Dato meramente administrativo del sistema, salvo que se utilice para análisis temporal complejo.

Preguntas

1. ¿Qué campos identifican directamente a una persona?

   Nombre, correo, teléfono y rfc.

2. ¿Qué campos no identifican por sí solos pero podrían contribuir a hacerlo?

   Id, edad, ciudad y codigo_postal.

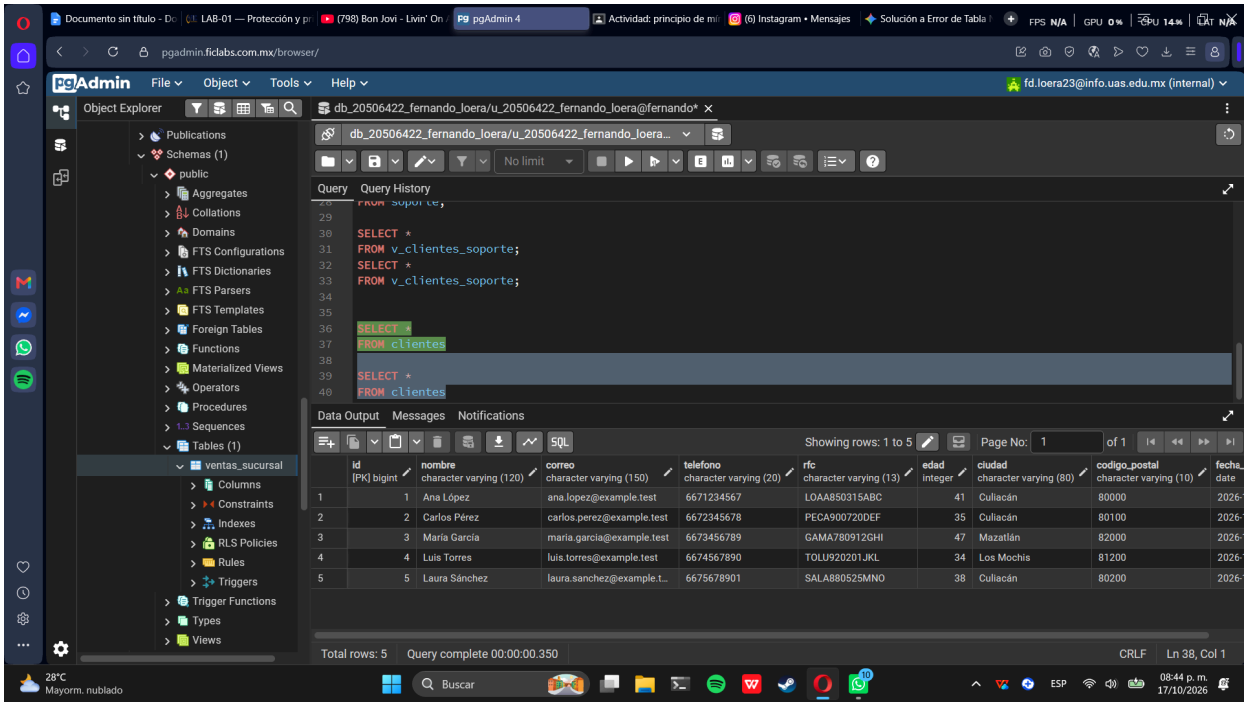
3. ¿Qué combinación de campos podría incrementar el riesgo de reidentificación?

   La combinación de `edad`, `ciudad` y `codigo_postal`. Juntos, estos datos reducen drásticamente el tamaño del grupo de personas al que podría pertenecer un registro, haciendo altamente probable distinguir a un individuo específico (efecto de cuasi-identificadores).

4. ¿Todos los datos que deben protegerse son necesariamente datos personales sensibles desde el punto de vista jurídico?

   No. Todo dato personal (cualquier información concerniente a una persona física identificada o identificable, como el nombre o correo) debe protegerse por ley. Sin embargo, los "datos personales sensibles" conforman una categoría jurídica más estricta que refiere a información íntima (estado de salud, origen étnico, creencias religiosas, preferencia sexual, etc.) cuya vulneración genera un riesgo grave de discriminación, y por tanto, exigen medidas de seguridad reforzadas y consentimiento expreso.

EVIDENCIA 2



¿Qué información continúa existiendo en la tabla original? En la tabla original (clientes), toda la información personal y sensible de los usuarios permanece intacta, completa y sin ningún tipo de enmascaramiento; esto incluye los correos electrónicos completos, los números de teléfono completos, los RFCs completos, así como las edades, ciudades y códigos postales de cada cliente.

¿Qué información puede visualizar el usuario soporte?

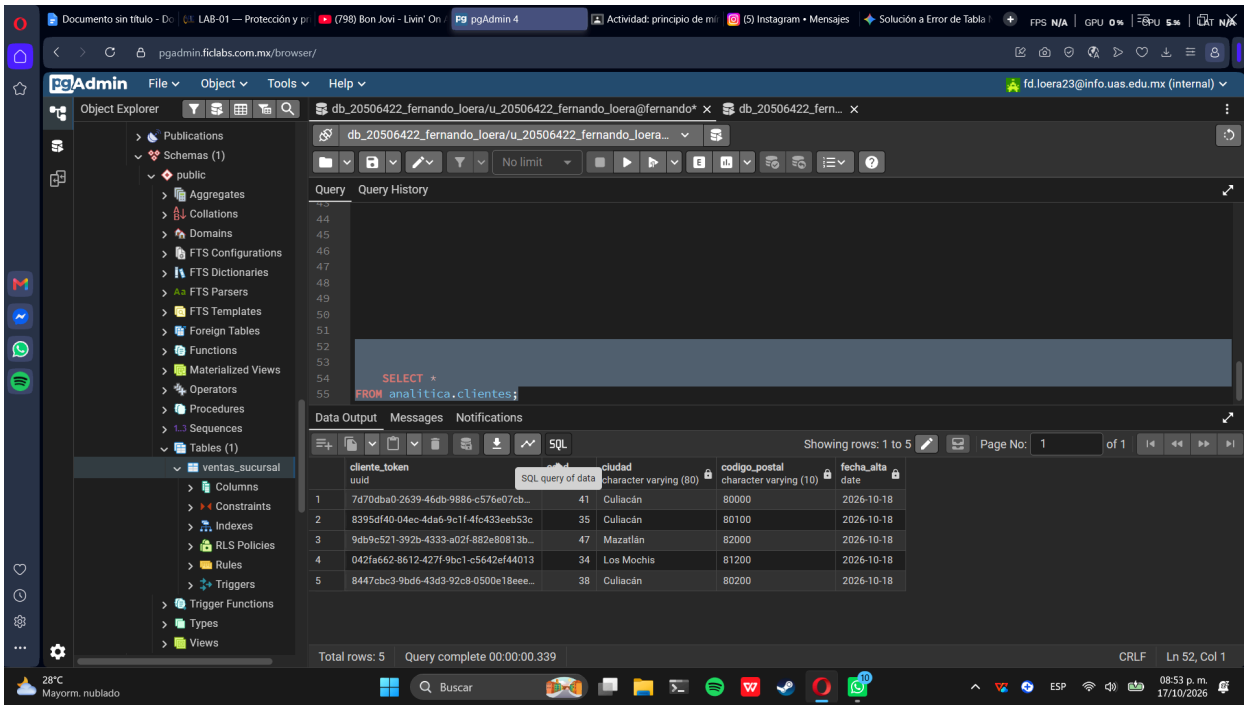
A través de la vista restrictiva (v_clientes_soporte), el usuario de soporte solo puede visualizar los datos sensibles de forma enmascarada: los correos electrónicos ocultos parcialmente con asteriscos (exhibiendo solo los primeros caracteres y el dominio), los teléfonos mostrando únicamente sus últimos 4 dígitos, y los RFCs mostrando solamente sus últimos 4 dígitos, junto con el ID y el nombre sin modificar.

¿Por qué no es suficiente ocultar los datos únicamente en la aplicación?

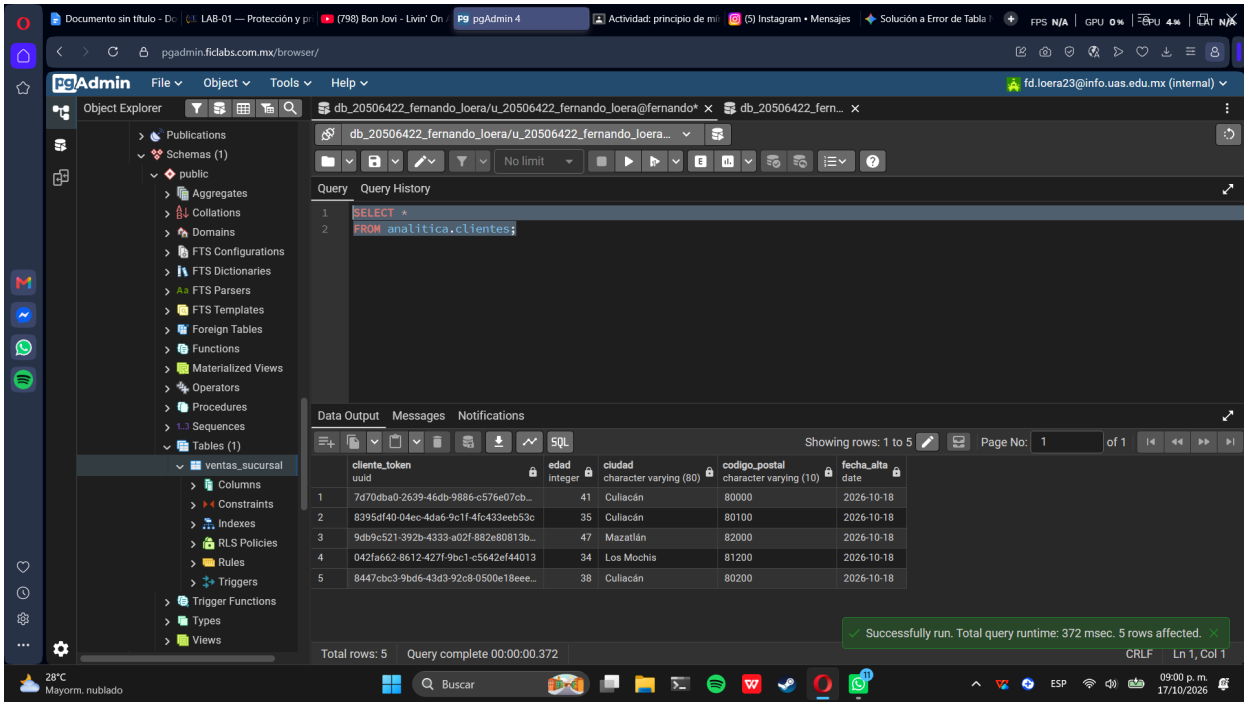
Porque la seguridad recaería en una sola capa que puede ser evitada. Si un usuario malintencionado, un script externo o un analista se conecta directamente a la base de datos (por ejemplo, mediante una herramienta de consultas o pgAdmin), podría saltarse la interfaz de la aplicación y acceder a toda la información sensible en texto plano de forma desprotegida.

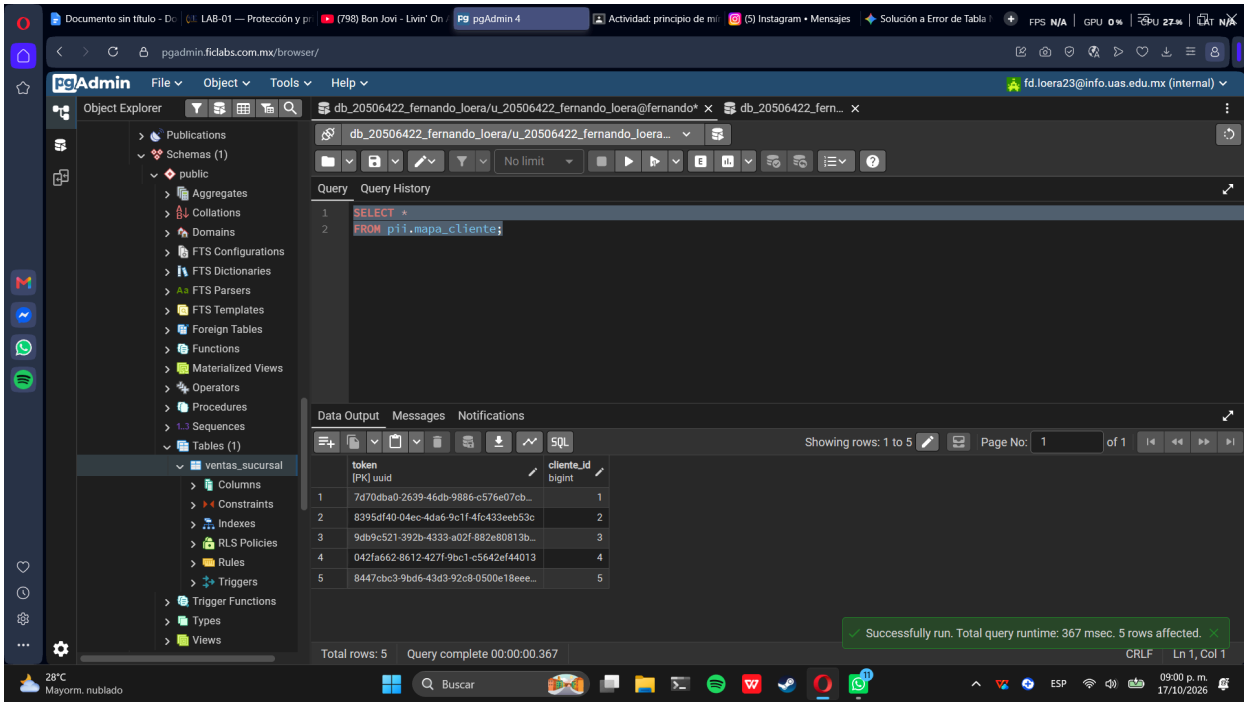
¿Qué ocurriría si soporte tuviera acceso directo a clientes? Se violaría el principio de menor privilegio, exponiendo información confidencial y datos personales delicados de los clientes de manera innecesaria. Esto incrementa de forma crítica el riesgo de filtraciones internas de datos, mal uso de la información y posibles incumplimientos a las normativas de privacidad y protección de datos.

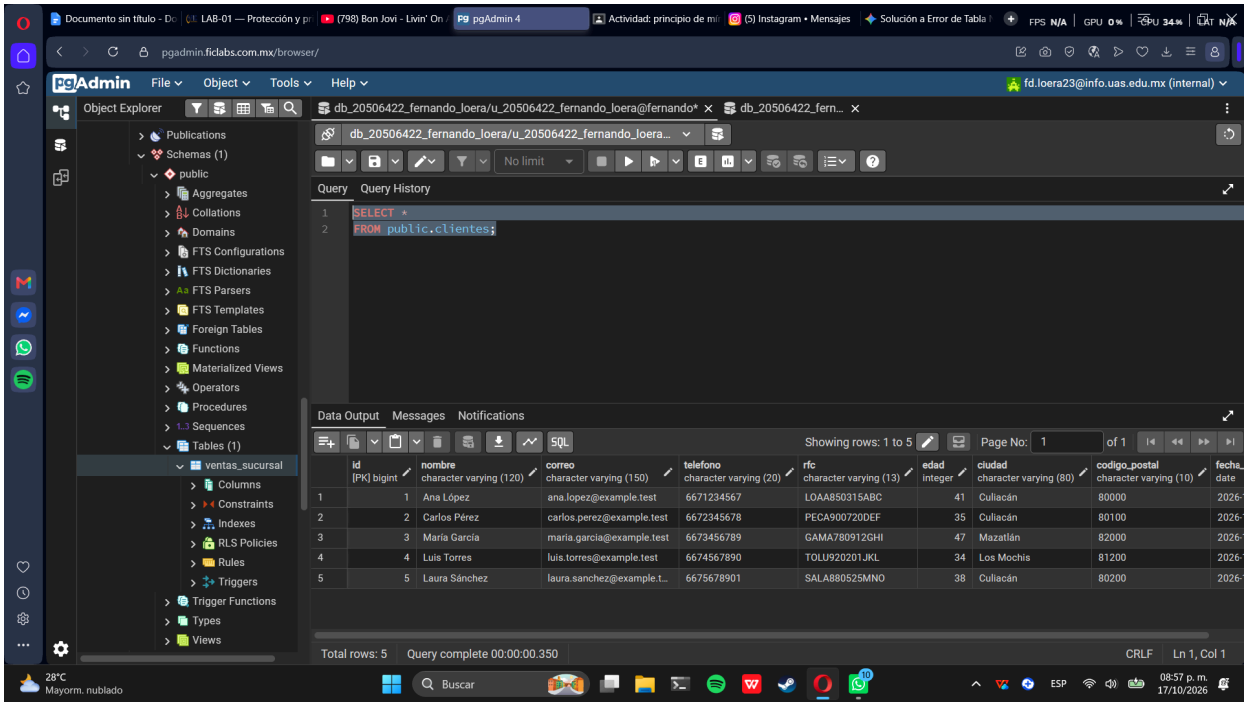
ACTIVIDAD 3



ACTIVIDAD 4


pgAdmin
File Object Tools Help
fd.loera23@info.uas.edu.mx (internal)
Object Explorer
db_20506422_fernando_loera/u_20506422_fernando_loera@fernando*
Query Query History
SELECT *
FROM analitica.clientes;
Data Output Messages Notifications
Showing rows: 1 to 5 Page No: 1 of 1
cliente_token uuid
edad integer
ciudad character varying (80)
codigo_postal character varying (10)
fecha_alta date
1 7d70dba0-2639-46db-9886-c576e07cb... 41 Culiacán 80000 2026-10-18
2 8395df40-04ec-4da6-9c1f-4fc433eeb53c 35 Culiacán 80100 2026-10-18
3 9db9c521-392b-4333-a02f-882e80813b... 47 Mazatlán 82000 2026-10-18
4 042fa662-8612-427f-9bc1-c5642ef44013 34 Los Mochis 81200 2026-10-18
5 8447cbc3-9bd6-43d3-92c8-0500e18eee... 38 Culiacán 80200 2026-10-18
Successfully run. Total query runtime: 372 msec. 5 rows affected.
Total rows: 5 Query complete 00:00:00.372
CRLF Ln 1, Col 1


pgAdmin
File Object Tools Help
fd.loera23@info.uas.edu.mx (internal)
Object Explorer
db_20506422_fernando_loera/u_20506422_fernando_loera@fernando*
Query Query History
SELECT *
FROM pii.mapa_cliente;
Data Output Messages Notifications
Showing rows: 1 to 5 Page No: 1 of 1
token [PK] uuid
cliente_id bigint
1 7d70dba0-2639-46db-9886-c576e07cb... 1
2 8395df40-04ec-4da6-9c1f-4fc433eeb53c 2
3 9db9c521-392b-4333-a02f-882e80813b... 3
4 042fa662-8612-427f-9bc1-c5642ef44013 4
5 8447cbc3-9bd6-43d3-92c8-0500e18eee... 5
Successfully run. Total query runtime: 367 msec. 5 rows affected.
Total rows: 5 Query complete 00:00:00.367
CRLF Ln 1, Col 1



:

1. ¿Qué ocurriría si analista pudiera consultar también `pii.mapa_cliente`? Se rompería por completo el propósito de la seudonimización y el aislamiento de datos. Al tener acceso a esa tabla de mapeo, el analista podría cruzar los tokens o identificadores enmascarados con la información personal real (PII), teniendo acceso libre a los datos sensibles que se suponía debían estar protegidos de su rol.
2. ¿Qué principio de seguridad se está aplicando al separar ambos accesos?

   Principio de Menor Privilegio: Se le otorga al usuario o rol únicamente el acceso estricto y necesario para realizar sus funciones analíticas, sin exponer datos confidenciales innecesarios.

   Separación de Funciones (Segregation of Duties - SoD): Se divide el acceso a los datos de negocio/analítica y a las llaves de descifrado o tablas de correlación para evitar que una sola persona o rol controle toda la cadena de privacidad.

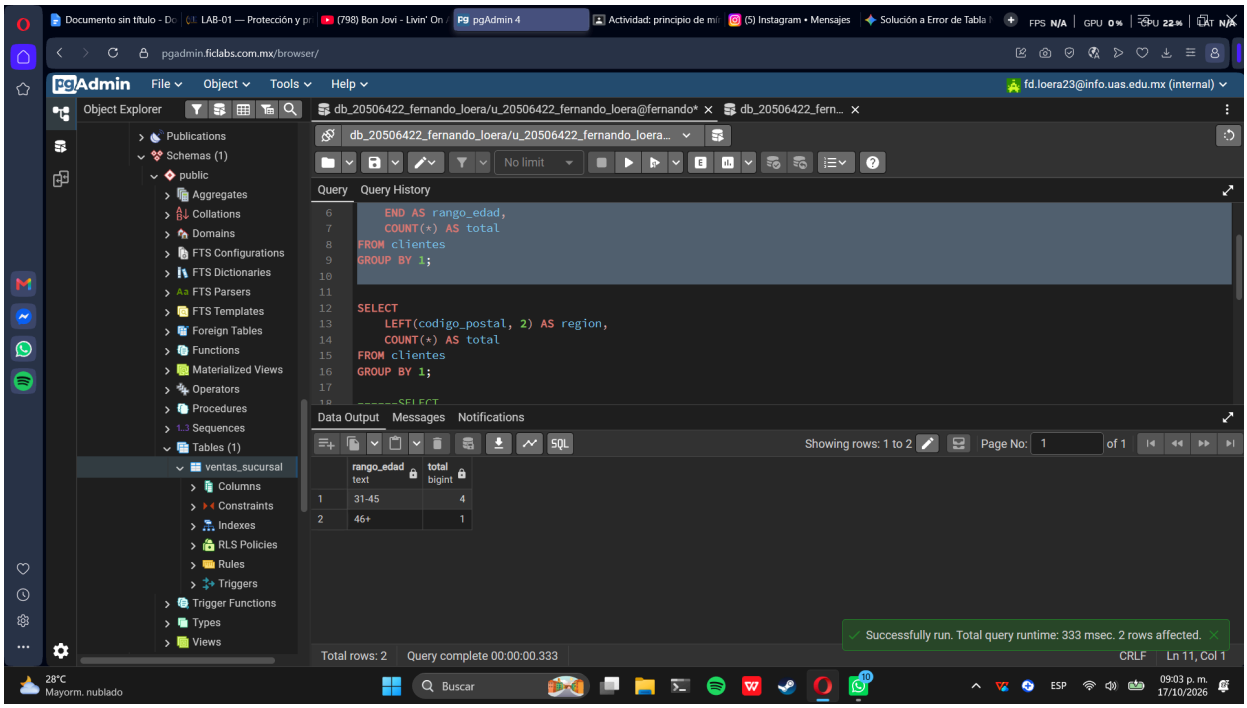
3. ¿Por qué la seudonimización no equivale a anonimización?

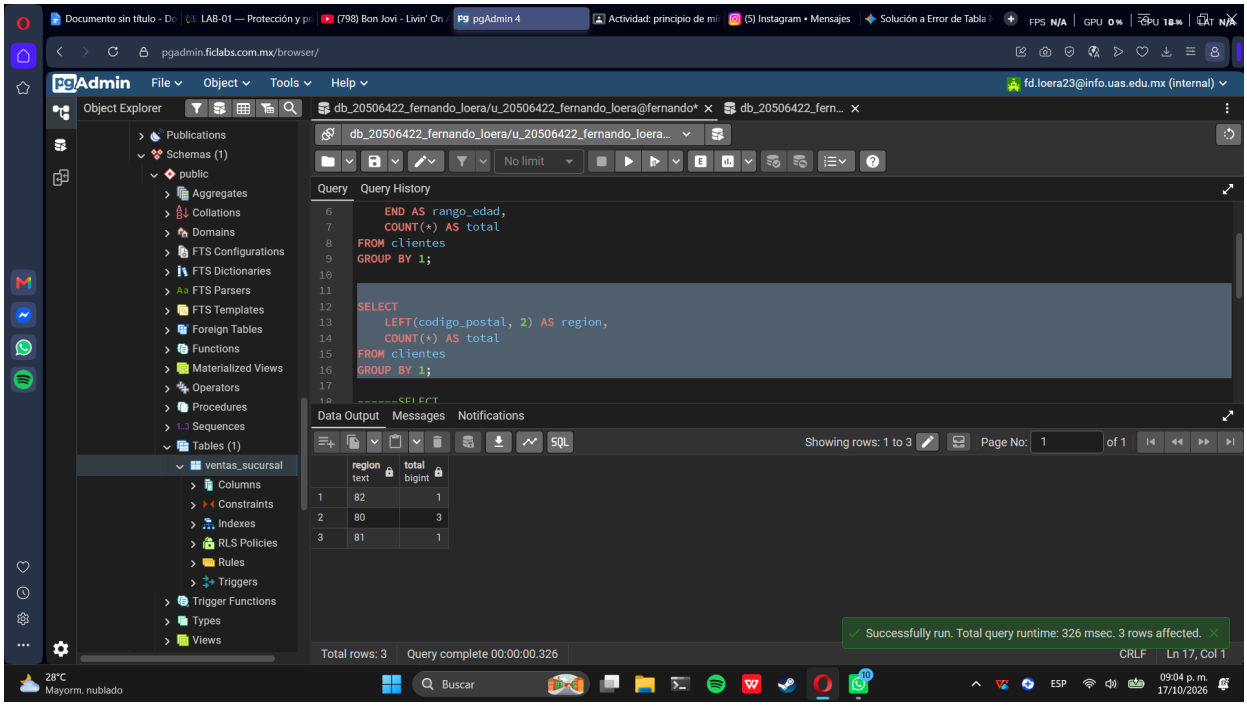
   Seudonimización: Es un proceso reversible donde los datos personales se sustituyen por un token o seudónimo, pero la información original sigue existiendo de forma segura en otra tabla o mediante una clave de cifrado, por lo que es posible re-identificar a la persona si se cuenta con los medios o permisos.

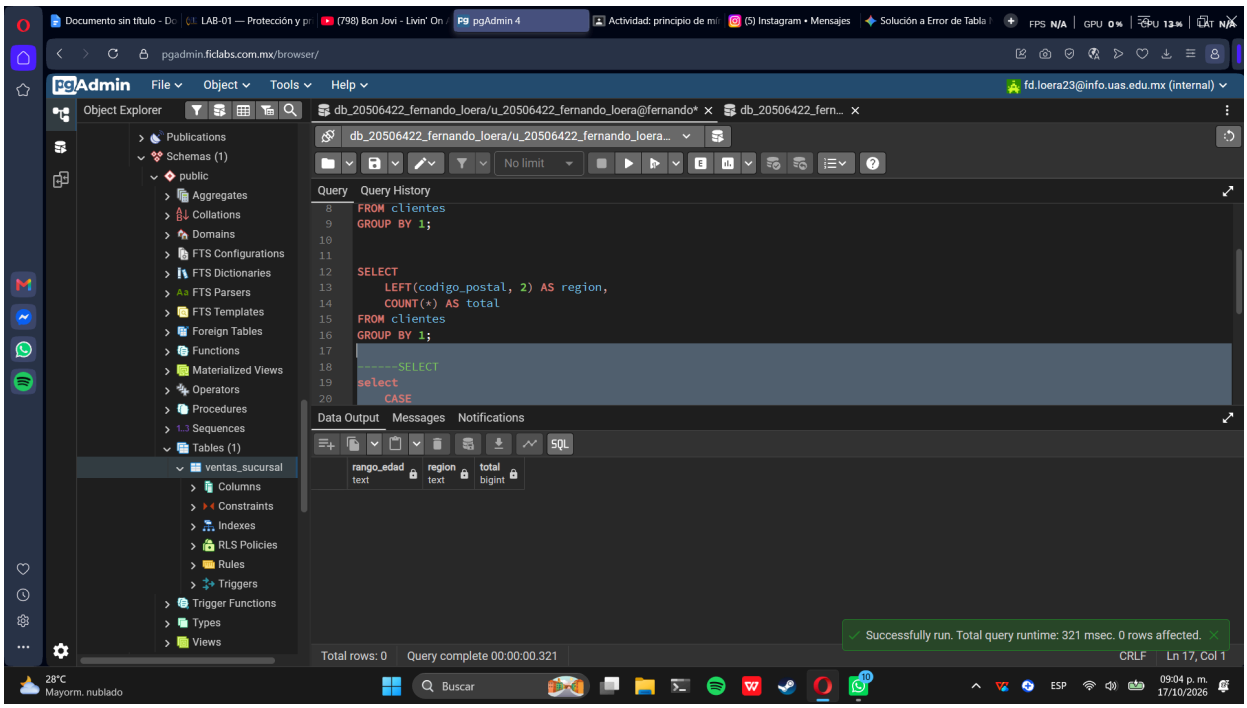
Anonimización: Es un proceso irreversible donde los datos se modifican o degradan de tal forma que es técnicamente imposible asociarlos a una persona física, ni siquiera utilizando información adicional o tablas de respaldo.

4. ¿Qué información permite volver a relacionar el token con una persona? La tabla de correlación, clave de mapeo o índice auxiliar (como el contenido en `pii.mapa_cliente`), que almacena de manera vinculada el registro del token o seudónimo junto con la llave primaria o los datos de identificación originales del individuo.

ACTIVIDAD 5




pgAdmin
File
Object
Tools
Help
Object Explorer
Query
Query History
SELECT
LEFT(codigo_postal, 2) AS region,
COUNT(*) AS total
FROM clientes
GROUP BY 1;
Data Output
Messages
Notifications
region text
total bigint
1 82 1
2 80 3
3 81 1
Total rows: 3
Query complete 00:00:00.326
Successfully run. Total query runtime: 326 msec. 3 rows affected.


pgAdmin
File
Object
Tools
Help
Object Explorer
Query
Query History
SELECT
LEFT(codigo_postal, 2) AS region,
COUNT(*) AS total
FROM clientes
GROUP BY 1;
------SELECT
select
CASE
Data Output
Messages
Notifications
rango_edad text
region text
total bigint
Total rows: 0
Query complete 00:00:00.321
Successfully run. Total query runtime: 321 msec. 0 rows affected.